

GlobalTrust Financial Services

Password & Multi-Factor Authentication Policy

Document ID	GTFS-SEC-002
Version	2.4
Classification	Internal
Owner	Information Security Department
Approved By	Priya Raman, Chief Information Security Officer (CISO)
Effective Date	01 January 2026
Review Date	01 January 2027

Table of Contents

1. Purpose
2. Scope
3. Password Policy
4. Password Creation Guidelines
5. Password Prohibitions
6. Multi-Factor Authentication (MFA)
7. Privileged Accounts
8. Password Managers
9. Account Lockout Policy
10. Security Monitoring
11. Common Attack Scenarios
12. Frequently Asked Questions
13. Appendices

1. Purpose

Strong authentication is the first line of defence for GlobalTrust Financial Services (GTFS). Weak or compromised credentials remain the leading cause of security breaches in the financial sector. This policy establishes mandatory password and multi-factor authentication standards to protect customer information, banking systems, financial transactions, and regulatory compliance.

This document supplements the Information Security Policy (GTFS-SEC-001) and applies to all individuals accessing GTFS systems. Remote employees must also comply with the Remote Work Policy (GTFS-HR-002) and VPN Access Guide (GTFS-SEC-003).

2. Scope

- **Employees** — all permanent and probationary staff.
- **Contractors** — external personnel with GTFS credentials.
- **Interns** — temporary programme participants.
- **Consultants** — advisory roles with system access.
- **Third-party vendors** — under contractual authentication requirements.
- **Service accounts** — non-interactive system identities.
- **Privileged administrators** — elevated access roles subject to additional controls.

3. Password Policy

All GTFS passwords must comply with the complexity requirements below. Passphrases are encouraged where supported and must meet a minimum length of **20 characters**.

Password Complexity Requirements

Requirement	Standard
Minimum length	14 characters
Maximum length	64 characters
Uppercase letters	At least one (A–Z)
Lowercase letters	At least one (a–z)
Numbers	At least one (0–9)
Special characters	At least one (!@#\$\$%^&*)
Passphrase minimum	20 characters (recommended)

Password Lifecycle

Passwords expire after **90 days**. A minimum password age of **1 day** prevents immediate reuse after a change. The system remembers the **12 previous passwords** and blocks reuse. Temporary passwords issued by IT expire after **24 hours** and must be changed on first login.

IMPORTANT: Default passwords on new accounts must be changed immediately. GTFS systems never store passwords in plain text; only salted cryptographic hashes are retained.

4. Password Creation Guidelines

Rating	Example	Assessment
Strong	Atlas-River-Phoenix-2026!	Long passphrase with mixed characters
Strong	K9#mP2\$VL8@xQ4nR7wT	Random complexity; no dictionary words
Weak	Password123!	Predictable pattern; commonly breached
Weak	GTFSemployee2026	Contains company name; easily guessed
Weak	Summer2025	Seasonal; dictionary-based

BEST PRACTICE: Use a unique passphrase for GTFS that you do not use on any personal website or service. Consider: four unrelated words plus numbers and symbols.

5. Password Prohibitions

- Reuse passwords across GTFS and external services.
- Share passwords with colleagues, managers, or IT staff.
- Write passwords on paper, sticky notes, or whiteboards.
- Store passwords in browser autofill without corporate password manager approval.
- Email passwords or send them via chat applications.
- Use personal information (birthdays, names, addresses).
- Include 'GTFS', 'GlobalTrust', or company product names.
- Use dictionary words alone without complexity.

COMMON MISTAKE: Legitimate GTFS IT staff will never ask for your password. Requests for credentials via email or phone are phishing attempts — report immediately.

6. Multi-Factor Authentication (MFA)

Multi-factor authentication requires two or more verification factors: something you know (password), something you have (token or app), or something you are (biometric). **MFA is mandatory for all employees** accessing GTFS systems.

Approved Authentication Methods

Method	Use Case	Status
Microsoft Authenticator	Primary MFA app for all employees	Approved — required
Hardware security keys (FIDO2)	Administrator and privileged access	Required for admins

Method	Use Case	Status
Biometric (Windows Hello / Touch ID)	Dependence on enrolled devices	Approved with MFA fallback
SMS one-time codes	Legacy fallback only	Discouraged — use Authenticator
Recovery codes	Emergency access when primary MFA unavailable	10 codes at enrollment

During MFA enrollment, the system generates **10 recovery codes**. Store these securely offline. Trusted devices may be registered for 90 days; re-authentication is required thereafter or when risk signals are detected.

SECURITY TIP: Never approve MFA prompts you did not initiate. This is a common indicator of credential theft.

7. Privileged Accounts

Administrator Requirements

Account Type	Additional Requirements
Administrator accounts	Separate from daily account; hardware key + Authenticator
Service accounts	Certificate or vault-managed passwords; no interactive login
Emergency (break-glass) accounts	Vaulted; monthly review; full session logging
Privileged access review	Quarterly recertification by system owners

Password Rotation Schedule

Account Type	Rotation Frequency	Notes
Standard employee	90 days (automatic)	Enforced by identity platform
Administrator	Every 60 days	Manual verification at rotation
Service account	Every 45 days	Automated via PAM vault
Break-glass	After each use + monthly review	CISO sign-off required

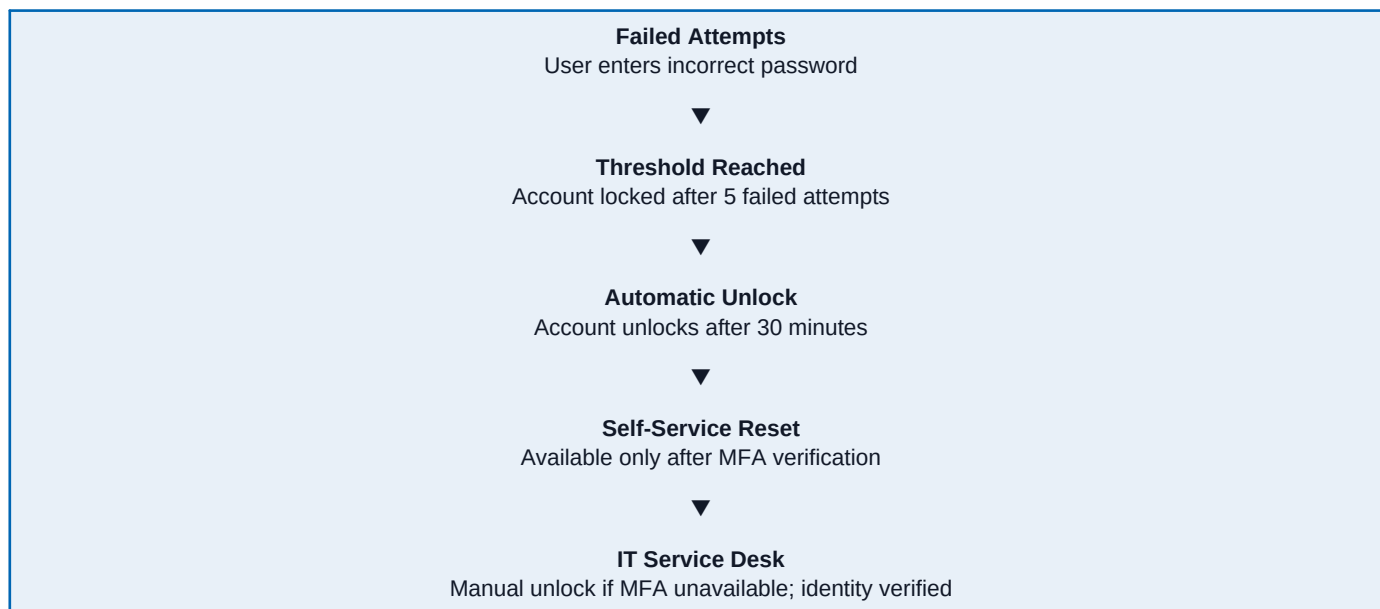
8. Password Managers

GTFS provides **Microsoft Entra Password Manager** (enterprise vault) for storing work-related credentials. Personal password managers must not store GTFS credentials unless approved by the CISO for specific roles.

- **Benefits** — Generate strong unique passwords; reduce reuse risk.
- **Storage** — Encrypted vault synced via corporate identity platform.
- **Sharing** — Team vaults for shared service credentials; audited access.
- **Master password** — Must meet all GTFS password complexity requirements.

9. Account Lockout Policy

Account Lockout Process



Password reset links sent via email expire after **15 minutes**. Self-service password reset is available only after successful MFA verification.

10. Security Monitoring

- **Failed login detection** — Real-time alerting after threshold breaches.
- **Impossible travel** — Logins from geographically distant locations within short windows.
- **Brute force protection** — Rate limiting and IP blocking on authentication endpoints.
- **Credential stuffing** — Detection of known breached password lists.
- **Suspicious login alerts** — Push notifications via Microsoft Authenticator.

Monitoring aligns with the Risk Management Framework (GTFS-RISK-001). Events are logged to the SIEM per GTFS-SEC-001.

11. Common Attack Scenarios

Attack	Defence
Phishing	Verify URLs; report suspicious emails; never share credentials
Password spraying / stuffing	Unique passwords; MFA; lockout after 5 attempts
Keylogging / brute force	EDR protection; rate limiting; 30-minute auto-unlock
Social engineering / SIM swap	Use Microsoft Authenticator; verify IT via portal

12. Frequently Asked Questions

Q: What is the minimum password length? A: 14 characters.

Q: What is the maximum password length? A: 64 characters.

- Q: How long should a passphrase be?** A: At least 20 characters is recommended.
- Q: How often must I change my password?** A: Every 90 days.
- Q: How many old passwords are blocked?** A: The last 12 passwords cannot be reused.
- Q: Can I change my password twice in one day?** A: No. Minimum password age is 1 day.
- Q: How many failed attempts before lockout?** A: 5 failed login attempts.
- Q: When does my account unlock?** A: Automatically after 30 minutes.
- Q: Is MFA required?** A: Yes. MFA is mandatory for all employees.
- Q: Which authenticator app should I use?** A: Microsoft Authenticator.
- Q: Do administrators need hardware keys?** A: Yes. Hardware security keys are required for administrators.
- Q: How many recovery codes do I get?** A: 10 codes generated during MFA enrollment.
- Q: How long is a password reset link valid?** A: 15 minutes.
- Q: How long do temporary passwords last?** A: 24 hours; must change on first login.
- Q: Can I reset my password without MFA?** A: No. Self-service reset requires MFA verification first.
- Q: How often are admin passwords rotated?** A: Every 60 days.
- Q: How often are service account passwords rotated?** A: Every 45 days.
- Q: What password manager is approved?** A: Microsoft Entra Password Manager.
- Q: How often are break-glass accounts reviewed?** A: Every month.
- Q: How often are privileged accounts reviewed?** A: Quarterly.

13. Appendices

Appendix A — Password Checklist

- Minimum 14 characters (20+ for passphrases)
- Mix of upper, lower, numbers, and symbols
- Unique — not used on any other service
- Not based on personal or company information
- Stored in Microsoft Entra Password Manager
- Changed before 90-day expiration
- MFA enrolled via Microsoft Authenticator

Appendix B — MFA Enrollment Guide

- Install Microsoft Authenticator; sign in to GTFS identity portal.
- Scan QR code; verify first MFA prompt; save 10 recovery codes offline.
- Administrators: register FIDO2 hardware security key as second factor.

Appendix C — Password Reset Process

- Navigate to the GTFS self-service password portal; authenticate with MFA.
- Receive reset link valid for 15 minutes; create compliant new password.

Refer to Section 6 for approved authentication methods. Employee obligations are summarised in the Employee Handbook (GTFS-HR-001).

Document Control

Document ID: GTFS-SEC-002 | Version 2.4 | Classification: Internal

Approved By: Priya Raman, CISO | Effective: 01 January 2026 | Review: 01 January 2027

Generated: 28 June 2026